Secure Configuration Standard

From the Office of the Chief Information Officer, State of Minnesota

Version: 1.9
Effective Date: 1/1/2016
Revised: 12/31/2024
Approved: John Israel, State of MN Chief Information Security Officer **Date:** 2/27/2026

Standard Statement

All State systems must be approved, inventoried, and securely configured with all unnecessary functionality disabled to support the confidentiality, availability, and integrity of State data.

Employees must abide by the terms of this standard. Employees who violate this standard may be subject to discipline, up to and including discharge.

Table 1. Secure Configuration Controls

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
1	Configuration Management Plan	A configuration management plan must be in place that: • Addresses roles, responsibilities, and configuration management processes and procedures. • Establishes a process for identifying configuration items throughout the system development life cycle (SDLC) and for managing the configuration of the configuration items. • Defines the configuration items for the system and places the configuration items under configuration management. • Protects the configuration management plan from unauthorized disclosure and modification.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
2	Change Control	Change control processes and procedures must be followed for all changes to systems. The change control process must include: • Documentation of all changes in change request forms. • Review of proposed changes by the change advisory board who approves or disapproves such changes with explicit consideration for security impact analyses. • Documentation of impact. • Documentation of change decisions associated with the system including approvals. • Functionality testing to verify that the change does not adversely impact the security of the system. • Back-out procedures. • Documentation of security flaws and flaw resolution. • Implementation of approved configuration-controlled changes to the information system. • Communication of significant changes to impacted individuals and organizations. • Implementation of all relevant Enterprise Security Standards on all new or changed systems and networks. Change control records must be maintained for the life of the system. Activities associated with changes must be periodically audited and reviewed.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
3	System Inventory	An inventory of all hardware and software must be maintained and updated through manual inventory checks or a network monitoring tool that automatically maintains the inventory. Inventory information must be updated at least annually and during installations, removals, and system updates. Inventory processes must prevent the duplication of inventory items. When a centralized inventory system is available, all hardware and software must be registered in it. The hardware and device inventory must include: • Data protection categorization. • Business owner. • Business owner contact information. • Business justification • Physical location. • Asset tag. • Serial number. • Operating system version. • Make and model of the device. • Host/machine name • IP address if static. • MAC address. • Service delivery support team owner. • Service delivery support team contact information. • Compliance obligations. The software and application inventory must include: • Application name. • Application ID. • Data protection categorization. • Business owner. • Business owner contact information. • Service delivery support team owner. • Service delivery support team contact information. • License Number. • Host devices. • Compliance obligations.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
4	Approved Software and Hardware	A list of all approved hardware and software along with any usage restrictions must be documented and maintained. All approved software must be: • Legally licensed. • Used in accordance with contract agreements and copyright laws. • Approved by MNIT. • Securely configured. Software and associated documentation protected by quantity licenses must be tracked to ensure copying and distribution comply with licensing agreements.	Low Moderate High
5	Unapproved Hardware and Software	Users must be prevented from installing or using unapproved or unlicensed hardware or software on State systems through automated methods. Systems must be continuously monitored for unapproved or unlicensed hardware or software. Any unapproved or unlicensed software or hardware must be disabled or removed. The use of peer-to-peer file sharing technology must be restricted to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction of copyrighted work.	Low Moderate High
6	Personal Devices	Devices not owned and supported by the State must be prohibited from storing, processing, or transmitting data with a data protection categorization of High or from supporting systems with a data protection categorization of high.	High
7	Unsupported Systems	Hardware must be replaced or retired prior to the end of vendor support. Operating systems and all software must be upgraded, replaced, or retired prior to end of unpaid support.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
8	Patch Management	All systems including firmware, operating systems, applications, and other software must be protected from known vulnerabilities by installing applicable vendor-supplied security patches. Install security patches according to the schedule specified in the Threat and Vulnerability Management Standard Where possible software and firmware updates must be tested in a test environment for effectiveness and potential side effects before installation. Where possible utilize a centrally managed the patch management process. Applications that go through vendor patch regression testing must be patched within 30 days of vendor approval, or 7 days for Severity 1 vulnerabilities after vendor approval.	Low Moderate High
9	Secure Configuration Standards	Secure configuration standards must be developed and maintained for all systems. These standards must address all known security vulnerabilities and be consistent with industry-accepted system hardening standards. These standards must be updated annually and when required due to system upgrades, patches, or other significant changes. Use CIS Level 1 benchmarks as a starting point if a specific secure configuration standard is not yet available.	Low Moderate High
10	Secure Configurations	Secure configurations must be implemented on all systems. Any deviations from the standards must be identified, documented, and approved. System configurations must be reviewed and updated annually and when required due to system upgrades, patches, or other significant changes. Older versions of baseline configuration of the system must be retained as deemed necessary to support rollback.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
11	Security Function Verification	Automated processes must be in place to: • Verify the correct operation of defined security functions upon system startup and restart, upon command by the administrator with appropriate privilege, and monthly. • Notify system administration of failed security verification tests. • Shut the information system down, restart the information system, or perform some other defined alternative action(s) when anomalies are discovered.	High
12	Least Functionality	Enable only necessary services, protocols, daemons, etc., as required for the function of the system. All unnecessary functionality, such as scripts, drivers, features, subsystems, file systems, and unnecessary web servers must be removed.	Low Moderate High
13	Process Isolation	The information system maintains a separate execution domain for each executing process.	Low Moderate High
14	System Defaults	Vendor-supplied default passwords, encryption keys, SNMP community strings, and other authenticators must be changed, and unnecessary default accounts must be removed or disabled before installing a system on the network. Public "read" and "write" access to files, objects, and directories that may directly impact system functionality and/or performance, or that contain sensitive information must be disabled.	Low Moderate High
15	Separate Functions	Implement only one primary function per server to prevent functions that require different security levels from co-existing on the same server. (For example, web servers, database servers, and DNS should be implemented on separate servers.)	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
16	Periodic Review	For systems in scope for ARC-AMPE: • The information system must be reviewed at least quarterly to identify and eliminate unnecessary functions, ports, protocols, and/or services. • Functions, ports, protocols, and services within the information system deemed to be unnecessary and/or non-secure must be disabled.	High
17	Boot Settings	System initialization (boot) settings must be password-protected	High
18	Memory Protection	Systems must be configured to protect memory from unauthorized code execution. (For example, utilizing data execution prevention or address space layout randomization.)	Low Moderate High
19	Mobile Code	Use of mobile code must be restricted by: • Defining acceptable and unacceptable mobile code and mobile code technologies. • Establishing usage restrictions and implementation guidance for acceptable mobile code and mobile code technologies. • Authorizing, monitoring, and controlling the use of mobile code within the information system. *NOTE: Mobile code technologies include, for example, Java, JavaScript, ActiveX, Postscript, PDF, Shockwave movies, Flash animations, and VBScript, which are common installations on most end user workstations. Usage restrictions and implementation guidance apply to both the selection and use of mobile code installed on servers and mobile code downloaded and executed on individual workstations and devices (e.g., tablet computers and smartphones).*	Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
20	Limit User Access	User functionality must be separate from system management/administration functionality. Non-privileged users must be prevented from executing privileged functions including disabling, circumventing, or altering implemented security safeguards/countermeasures.	Low Moderate High
21	Information in Shared Resources	The system must prevent unauthorized or unintended information transfer via shared system resources by ensuring that: • Users of shared system resources cannot intentionally or unintentionally access information remnants, including encrypted representations of information, produced by the actions of a prior user or system process acting on behalf of a prior user. • System resources shared between two (2) or more users are released back to the information system and are protected from accidental or purposeful disclosure.	Low Moderate High
22	Network Disconnect	Network connections associated with a communications session must be terminated at the end of the session or: • Forcibly de-allocates communications session Dynamic Host Configuration Protocol (DHCP) leases after seven (7) days. • Forcibly disconnects inactive Virtual Private Network (VPN) connections after thirty (30) minutes or less of inactivity. *Note: This control addresses the termination of network connections that are associated with communications sessions (i.e., network disconnect) in contrast to user-initiated logical sessions.*	High
23	Remote Management	All non-console administrative access must be encrypted using strong cryptography. Technologies such as SSH, VPN, or TLS must be used for web-based management and other non-console administrative access.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
24	Secure Name/Address Resolution Service	All equipment accessible via a network must be registered in an approved Name/Address Resolution Service. Name and Address Resolution Service must be configured to: • Support both forward and reverse lookup of any network name, network alias, or IP address in use on state networks. • Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries. • Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable verification of a chain of trust among parent and child domains, when operating as part of a distributed, hierarchical namespace. • Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources.	Low Moderate High
25	Split Tunneling	Devices must be prevented from simultaneously establishing connections with internal state systems or networks and communicating via some other connection to resources in external networks.	Low Moderate High
26	Secure Services	Additional security features must be applied for any required services, protocols or daemons that are insecure to address the weaknesses in that service, protocol, or daemon (For example, use secured technologies such as SSH, S-FTP, SSL, or IPSec VPN to protect insecure services such as NetBIOS, file-sharing, Telnet, FTP, etc.).	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
27	File Sharing	File sharing must be disabled on all wireless clients.	Low Moderate High
28	Integrity	Electronic mechanisms to corroborate that data with high integrity needs has not been altered or destroyed in an unauthorized manner must be implemented. Possible mechanisms could include: • Error-correcting memory • Magnetic disk storage • Digital signatures • Check sum technology.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
29	Virtualization	Virtual environments must be configured to: • Secure programs that control the hypervisor and restrict them to authorized administrators only. • Enforce separation between VMs. • Disable functions that allow one VM to share data with the hypervisor or another VM, such as clipboard sharing or shared disks. • Disable special VM functions available to system administrators in a virtualized environment that can leverage the shared memory space in a virtual environment between the hypervisor and VM. • Prevent data from being dumped outside of the VM when system errors occur. Backups (virtual machine snapshot) must be properly secured and must be stored in a logical location where the backup is only accessible to those with a need-to-know. Virtual environments containing Criminal Justice Information must: • Isolate the host from the virtual machine. • Physically separate Internet facing Virtual Machines (web servers, portal servers, etc.) from internal Virtual Machines. • Locate device drivers that are “critical” within a separate guest operating system.	High
30	Decommissioning Virtual Devices	All disk space utilized by a virtual device must be sanitized using a secure erase function once the virtual device is decommissioned.	Moderate High
31	Remote Access	Remote access connections must: • Be formally authorized prior to allowing such connections. • Restrict the use of privileged command execution to only those necessary and authorized for compelling operational needs. • Prohibit FTI or CJI from being accessed from outside the United States.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
32	Resource Availability	The information system must protect the availability of resources by allocating resources by priority and/or quota.	Low Moderate High
33	Denial of Service Protection	Implement security safeguards to protect against or limit the effects of the types of denial-of-service attacks defined on the following websites: • CISA: Understanding and Responding to Distributed Denial-of-Service Attacks (cisa.gov) • http://www.sans.org/dosstep OWASP: Denial of Service - OWASP Cheat Sheet Series	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
34	Controlled Maintenance	All system maintenance must: • Be scheduled, performed, documented, and reviewed in accordance with manufacturer or vendor specifications and internal State requirements. • Ensure support and/or spare parts for defined key system components (defined in the applicable security plan) are obtained within the applicable Recovery Time Objective (RTO) specified in the contingency plan. • Be approved by authorized personnel and monitored. • Not remove the system from the facility without approval from authorized personnel. • Only be performed using inspected and approved maintenance tools and media. ○ Maintenance tools must be inspected for Not Public Data prior to removal from the facility and any not public data must be securely removed from the device (sanitized or destroyed). • Validate security controls are still functioning properly after maintenance is completed. • Require that the applicable business owner (or an official designated in the applicable security plan) explicitly approve the removal of the information system or system components from organizational facilities for off-site maintenance or repairs. • Sanitize equipment to remove all not public data from associated media prior to removal from State facilities for off-site maintenance or repairs. • Be documented in maintenance records.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
35	Personal Firewall	A personal firewall must be installed and actively running on all end user devices that have a full-feature operating system (i.e., laptops, desktops, or tablets with Windows or Linux/Unix operating systems). At a minimum, the personal firewall must: • Be activated when connected to an untrusted network. • Manage program access to the Internet. • Block unsolicited requests to connect to the user device. • Filter incoming traffic by IP address or protocol. • Filter incoming traffic by destination ports. • Maintain an IP traffic log. • Not be alterable by the users of the device.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
36	Mobile Device Management	Mobile device management must be used to enforce secure configurations on all State, employee, or contractor mobile devices with access to State data or networks. All mobile device access to State systems or networks must be authorized. Mobile device management must be configured to: • Remotely lock the device if necessary. • Remotely wipe the device if necessary. • Set and lock the device configuration. • Detect “rooted” and “jailbroken” devices. • Enforce folder or disk level encryption. • Apply mandatory policy settings on the device. • Detect unauthorized configurations or software/applications. • Disable system functionality that provides for automatic execution of code on mobile devices without user direction. • For devices containing or accessing FTI ○ Disable wireless personal area networks that allow a mobile device to connect to a computer via Bluetooth or near field communication (NFC) for data synchronization and storage. • Access to hardware, such as the digital camera, global positioning system (GPS), and universal serial bus (USB) interface, must be disabled to the extent possible.	Low Moderate High
37	Encrypt End User Devices	All laptops, desktops and mobile devices must be encrypted.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
38	Multi-Functional Devices and High-Volume Printers	Multi-functional devices (MFD) or High-Volume Printers must meet the following requirements: • Maintain a current security baseline for secure configuration and operation of the MFD or High-Volume Printer. • Implement least functionality controls including disabling all unneeded network protocols, services, and assigning a dedicated static IP address to the MFD or High-Volume Printer. • Configure access enforcement controls correctly, including access controls for file shares, administrator and non-administrator privileges, and document retention functions. • Lock MFD's or High-Volume Printers with a mechanism to prevent physical access to the hard disk. Ensure firmware is up to date with the most current firmware available and should be currently supported by the vendor. • Enable logging of devices and print spoolers, including logging of user access and fax logs (if fax is enabled). Logs must be collected and reviewed by a security administrator. • Disposal of all hardware follows media sanitization and disposal procedure requirements.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
39	Storage Area Networks	SAN environments must meet the following requirements: • Data with a Data Protection Categorization of High must be segregated from other agency data within the SAN environment. • Access controls must be implemented and strictly enforced for all SAN components to limit access to disks containing to authorized users. • Fiber channel devices must be configured to authenticate other devices with which they communicate in the SAN and authenticate administrator connections. • Data with a Data Protection Categorization of High must be encrypted while in transit within the SAN environment. SAN management traffic must also be encrypted for SAN components. • All components of the SAN must be hardened in accordance with State security baseline configuration standards. • SAN components must maintain logs which must reviewed at least weekly to track access to Data Protection Categorization of High in the SAN environment.	High
40	Virtual Desktop Infrastructure	Secure Virtual Desktop Infrastructure (VDI) that is used as a means of remote access to data or systems with a Data Protection Categorization of High by: • Segregating VDI components so that boundary protections can be implemented, and access controls are granulized. • Utilizing an access control system that is specifically configured to address the complicated nature of the environment—ensure only authorized clients who conform to State security policy are permitted access to the VDI. • Configuring the hypervisor, management consoles, and other VDI components using the secure configuration guidelines provided by the vendor.	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
41	Web Browser	Web browsers must: • Have security enhancements, such as pop-up blocker and content filtering enabled. • Be configured in accordance with the principle of least functionality and unnecessary items, such as third-party add-ons, must be disabled. • Only enable Java if there is a valid business need and it has been approved.	Low Moderate High
42	Non-Repudiation	Individuals (or processes acting on behalf of an individual) must be prevented from falsely denying having performed a particular action by employing non-repudiation techniques or mechanisms including, for example, digital signatures and digital message receipts.	High
43	Mask Data on Display	Data with a data protection categorization of High must be masked when displayed except for personnel who need access to the data for job duties.	High
44	Removable Media	The use of system and removable media (CD, USB stick, portable hard drive, etc.) on workstations must only be enabled for users with an approved business need. If system and removable media boot access is authorized, boot access must be password protected.	Low Moderate High
45	Collaborative Computing Devices	All collaborative computing devices (networked white boards, cameras, microphones, etc.) must be explicitly authorized and configured to: • Prohibit remote activation. • Provide an explicit indication of use to users physically present at the devices.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
46	Encryption in Transit	Strong cryptography and security protocols must be used to protect State data during transmission including the following: • Always encrypt data with a data protection categorization of High in transmission. • Encrypt data with a data protection categorization of Moderate in transmission over external networks. • Only accept trusted keys and certificates. • Only support secure versions or configurations of the protocol in use. • Use an encryption strength that is appropriate for the encryption methodology in use.	Moderate High
47	Certificate Management	All public key certificates used in State systems must be: • Authorized by a supervisor or a responsible official. • Implemented using a secure process that verifies the identity of the certificate holder. • Issued only to the intended party. • Issued from trusted secure internal certificate authority or obtained from an approved service provider. • Valid for no longer than 3 years. • Revoked if any of the following is true: ○ Associated private key is compromised. ○ Management requests revocation ○ Certificate is no longer needed	Low Moderate High
48	Encryption at Rest	All data with a data protection categorization of High, including Federal Tax Information (FTI), must be encrypted at rest using FIPS 140-2 validated encryption methods. • The encryption process must ensure that all stored FTI always remains protected, including during backups and in any replicated environments.	High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
49	FIPS Certification	All mechanisms used to encrypt data must be FIPS 140-2 compliant and operate using the FIPS 140-2 compliant module.	Low Moderate High
50	Disk Encryption	Independent logical access controls must be used in addition to operating system and database access controls if disk encryption is used (rather than file- or column-level database encryption). Decryption keys must not be associated with user accounts.	High
51	Encryption Key Security	Encryption keys must be protected against disclosure and misuse by: • Restricting access to cryptographic keys to the fewest number of individuals necessary. • Always securely storing secret and private keys used to encrypt/decrypt State data in one (or more) of the following forms: ○ Encrypted with a key-encrypting key that is at least as strong as the data-encrypting key and that is stored separately from the data-encrypting key. ○ Within a secure cryptographic device (such as a host security module (HSM)). ○ As at least two full-length key components or key shares, in accordance with an industry-accepted method. • Storing encryption keys in the fewest possible locations. • Securely distributing encryption keys.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
52	Encryption Key Management	Encryption keys must be: • Strong ○ At least 10 characters long. ○ Not a dictionary word. ○ At least one (1) upper case letter, one (1) lower case letter, one (1) number and one (1) special character. • Changed at the end of their cryptoperiod, as recommended by the application vendor or key owner and based on industry best practices and guidelines. • Retired or replaced when the integrity of the key has been weakened or keys are suspected of being compromised. • Managed using split knowledge and dual control if manual clear-text encryption key-management operations are used.	Low Moderate High
53	Key Substitutions	The substitution of keys coming from unauthorized sources or unexpected processes must be prevented.	Low Moderate High
54	Key Custodians	Encryption key custodians must formally acknowledge that they understand and accept their key-custodian responsibilities.	Low Moderate High
55	Production Data in Non-production Environments	Production data must not be used in non-production environments.	Low Moderate High

Roles & Responsibilities

- Employees, Vendors, and Contractors

    - Be aware of and follow relevant information security policies, standards, and procedures.
    - Ensure information security is incorporated into processes and procedures.
    - Ensure contract language with vendors and contractors includes required information security controls.
    - Consult with information security staff on the purchase and procurement of information technology systems or services.
    - Contact information security staff or email GRC@state.mn.us with questions about the information security policies, standards, or procedures.
- Supervisors and Managers
    - Ensure employees and contractors are proficient in the information security policies, standards, and procedures that are relevant to their role.
    - Hold employees accountable for following the information security policies, standards, and procedures.
- Information Technology Personnel
    - Apply appropriate controls to the design, operation and maintenance of systems, processes, and procedures in conformance with the information security policies, standards, and procedures.
- Information Security Personnel
    - Develop, maintain, and assess compliance with the information security policies, standards, and procedures.
    - Develop, maintain, and implement a comprehensive information security program.
    - Provide training on information security policies, standards, and procedures.
    - Assist agencies and personnel with understanding and implementing information security policies, standards, and procedures.
    - Notify appropriate personnel of applicable threats, vulnerabilities, and risks to State data or systems.
- Agency Data Practices Personnel
    - Assist agencies and personnel with questions on proper data use, collection, storage, destruction, and disclosure.

Applicability

This policy applies to all departments, agencies, offices, councils, boards, commissions, and other entities in the executive branch of Minnesota State Government.

Related Information

Information Security and Risk Management Program Policy

Secure Systems Development and Acquisition Policy

Technical Security Policy

Threat and Vulnerability Management Standard

State Standards and Authoritative Source Cross Mapping

Glossary of Information Security Terms

DNS Naming Guideline for Servers

History

Table 2. Version History

Version	Description	Date
1.0	Initial Release	7/8/2015
1.1	Added Compliance Enforcement Date	12/29/2015
1.2	Updated Compliance Enforcement Date and New Template	12/20/2016
1.3	Updated Compliance Enforcement Date and New Template	10/26/2017
1.4	Scheduled Document Refresh	3/10/2020
1.5	Scheduled Document Refresh	11/1/2021
1.6	Clarified language and expanded scope of some controls to include all data categories	10/1/2022
1.7	Clarified when software is considered unsupported; included use of CIS benchmarks if no secure config is available; moved control addressing use of prod data in non-prod environment into this standard from the Secure Systems Development and Acquisition Standard	10/1/2023
1.8	Added enforcement language; removed broken URLs; clarified some requirements related to IRS; clarified requirements for name resolution; updated version and revision date	12/2/2024
1.9	Replaced outdated MARS-E reference with ARC-AMPE; corrected wording for secure configurations control.	1/12/2026

Contact

GRC@state.mn.us